

Tech Biz Security Internship

Week 4 · Task 12 — OWASP Top 10 Web Vulnerabilities Overview

Submitted by: Mah Noor

Intern Name	Mah Noor
THM Username	mahnnorchaudary
Program	Tech Biz Security — Ethical Hacking Track
Task	Week 4 · Task 12 — OWASP Top 10 Web Vulnerabilities Overview
Submission Date	September 13, 2026

1. TryHackMe — Rooms Completed

The assigned room "OWASP Top 10 - 2021" was not available on the free tier, so equivalent OWASP-focused free rooms were completed instead as per task instructions. The following rooms were completed and proof screenshots are attached:

- Web Application Basics — 11 tasks completed, 208 points earned
- OWASP Top 10 2025: IAAA Failures — 6 tasks completed, 56 points earned
- OWASP Top 10 2025: Insecure Data Handling — 4 tasks completed, 24 points earned
- OWASP Top 10 2025: Application Design Flaws — 6 tasks completed, 32 points earned
- Badge Earned: OWASP Top 10 — "Understanding every OWASP vulnerability"

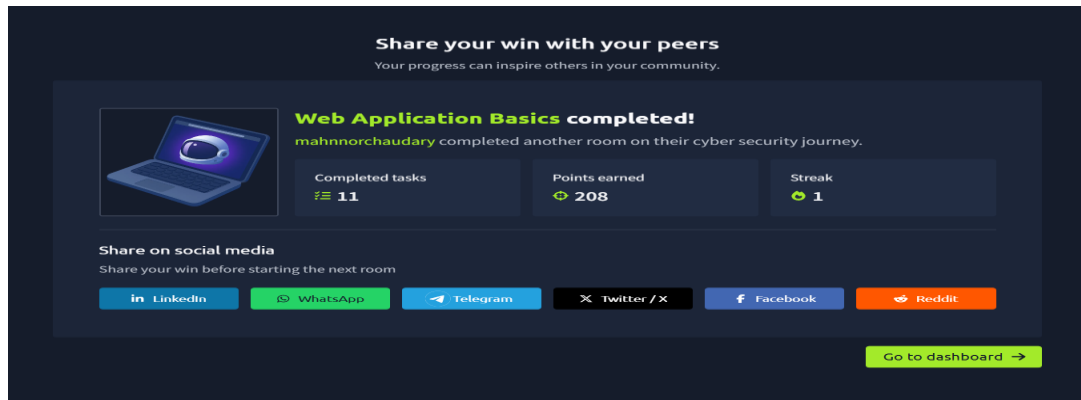


Figure 1 — Web Application Basics completed (11 tasks, 208 points)

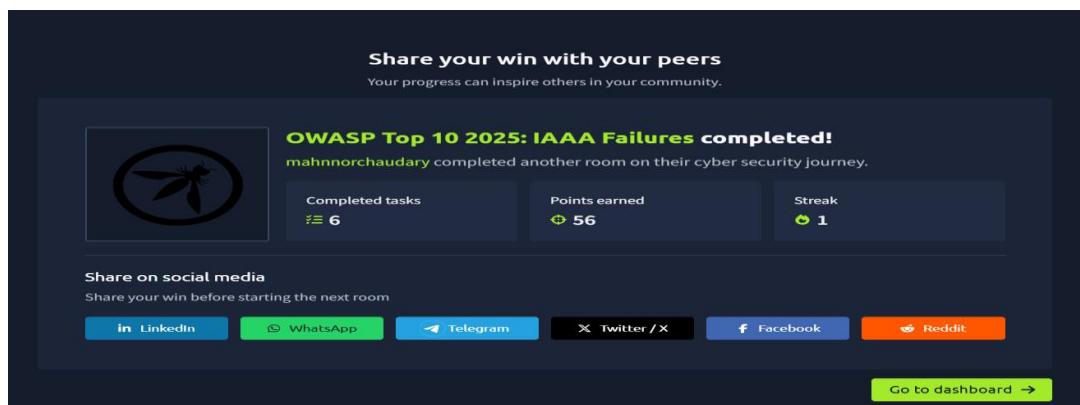


Figure 2 — OWASP Top 10 2025: IAAA Failures completed (6 tasks, 56 points)

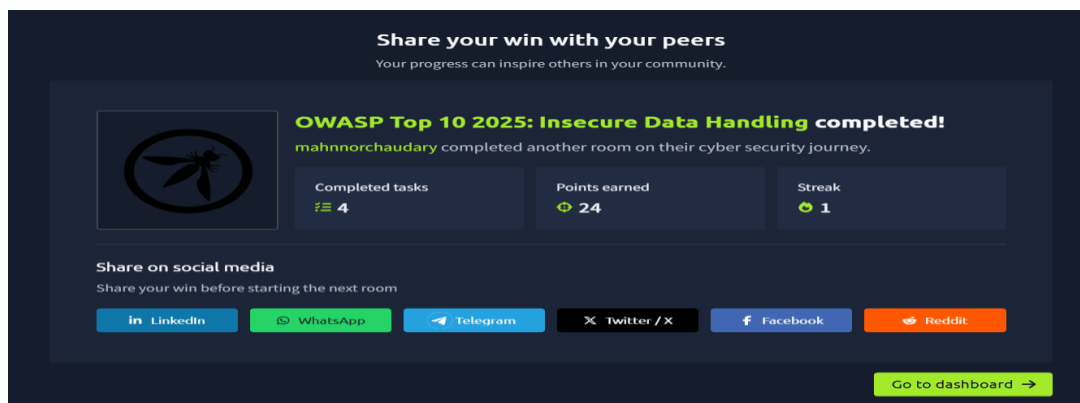


Figure 3 — OWASP Top 10 2025: Insecure Data Handling completed (4 tasks, 24 points)

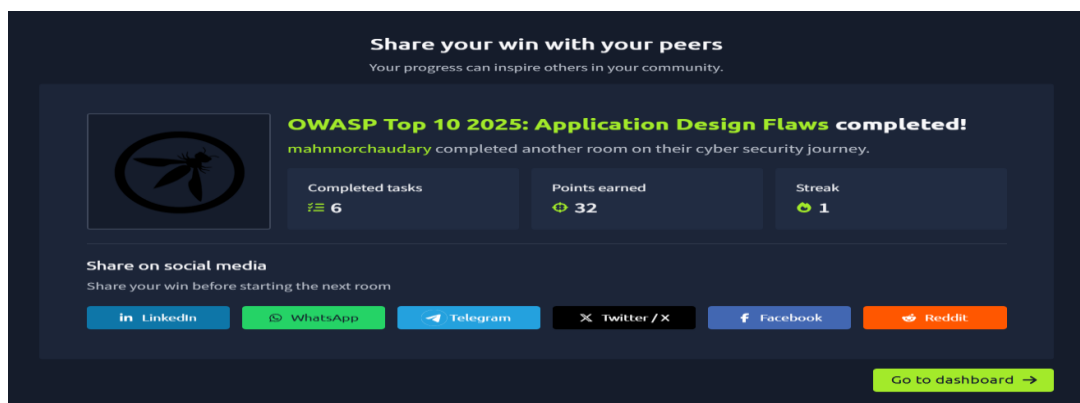


Figure 4 — OWASP Top 10 2025: Application Design Flaws completed (6 tasks, 32 points)

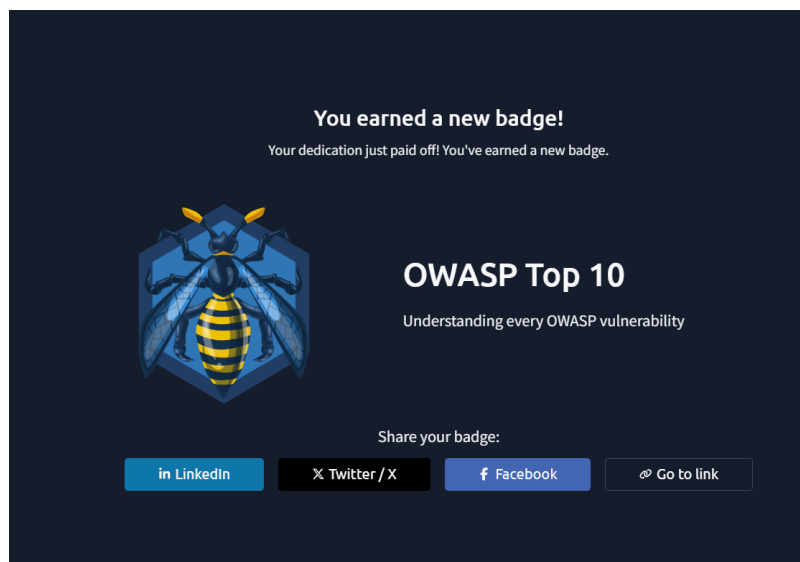


Figure 5 — OWASP Top 10 Badge earned on TryHackMe

2. OWASP Top 10 (2021) — Summary

The OWASP Top 10 is the industry-standard list of the most critical web application security risks, published by the Open Web Application Security Project. Below is a summary of all 10 categories with meanings, real-world breach examples, and DVWA module mappings.

#	Vulnerability	Meaning	Real-World Breach	DVWA Module
A01	Broken Access Control	Users can access resources/functions beyond their permissions — e.g. viewing another user's data by changing an ID in the URL.	Facebook (2018) — attackers accessed 50M user accounts by exploiting a token flaw.	Authorisation Bypass
A02	Cryptographic Failures	Sensitive data (passwords, credit cards) stored or transmitted without proper encryption — weak algorithms or no encryption at all.	LinkedIn (2012) — 117M passwords hashed with unsalted MD5, easily cracked.	Weak Session IDs, Cryptography
A03	Injection	Untrusted data sent to an interpreter (SQL, OS, LDAP) as part of a command — attacker manipulates the query to extract or destroy data.	Heartland Payment (2008) — SQL injection exposed 130M credit card numbers.	SQL Injection, Command Injection
A04	Insecure Design	Fundamental design flaws — security was never considered during architecture, not just bad implementation.	Twitter (2022) — design flaw allowed phone number/email to user account enumeration affecting 5.4M users.	N/A (design-level)
A05	Security Misconfiguration	Default credentials, unnecessary features enabled, missing patches, overly permissive cloud settings.	Capital One (2019) — misconfigured AWS WAF allowed SSRF; 100M records exposed.	DVWA Security settings (Low/Medium/High)
A06	Vulnerable & Outdated Components	Using libraries/frameworks with known CVEs — the attacker exploits the component, not your code.	Equifax (2017) — unpatched Apache Struts CVE; 147M records stolen.	N/A (dependency level)
A07	Auth & Identity Failures	Weak passwords allowed, no MFA, broken session management, credential stuffing not blocked.	Dunkin' Donuts (2019) — credential stuffing attack compromised customer accounts.	Brute Force, Weak Session IDs
A08	Software & Data Integrity Failures	Code or data pipelines lack integrity checks — malicious updates or deserialised objects can execute arbitrary code.	SolarWinds (2020) — tampered software update distributed to 18,000+ organisations.	N/A
A09	Security Logging & Monitoring Failures	Attacks succeed because there are no logs, alerts, or detection — breaches go unnoticed for months.	Yahoo (2013-2016) — breach of 3B accounts went undetected for 3 years.	N/A (monitoring level)
A10	Server-Side Request Forgery	Server is tricked into making requests to internal resources on behalf of the attacker — bypasses firewall.	Capital One (2019) — SSRF via metadata endpoint exposed AWS credentials.	Open HTTP Redirect

3. Deep Dive — Top 3 Vulnerabilities

The three most critical OWASP categories were studied in detail: Broken Access Control (A01), Cryptographic Failures (A02), and Injection (A03).

A01 — Broken Access Control

What it is: Users are able to act outside of their intended permissions — accessing data or performing actions that should be restricted.

How it works: An attacker changes a URL parameter (`?user_id=123` → `?user_id=124`) and sees another user's data. Or a regular user accesses `/admin` without being an administrator.

Real breach: Facebook (2018): A bug in the "View As" feature allowed attackers to steal access tokens. 50 million accounts were exposed. Attackers exploited the access control flaw to generate tokens for other users.

DVWA — Authorisation Bypass: DVWA has a dedicated "Authorisation Bypass" module. At Low security, certain pages are accessible without authentication. The Broken Access Control logs can also be viewed from the DVWA Security page.

Prevention: Implement deny-by-default access control. Validate permissions on the server side for every request. Never rely on client-side checks alone. Log access control failures and alert on repeated failures.

A02 — Cryptographic Failures

What it is: Sensitive data (passwords, credit cards, personal information) is stored or transmitted without adequate encryption, or with broken/weak cryptographic algorithms.

How it works: Passwords stored as MD5 hashes without salt can be cracked in seconds using rainbow tables. Data transmitted over HTTP (not HTTPS) can be intercepted via man-in-the-middle attacks.

Real breach: LinkedIn (2012): 6.5 million password hashes were leaked (later found to be 117 million). The passwords were hashed with MD5 without any salt — making them trivially crackable. The full extent wasn't discovered until 2016.

DVWA — Weak Session IDs & Cryptography: DVWA's "Weak Session IDs" module demonstrates how predictable session tokens can be exploited. The "Cryptography" module covers encryption weaknesses. On Low security, session IDs increment predictably (1, 2, 3...) making them easy to guess.

Prevention: Use bcrypt, Argon2, or scrypt for password hashing. Always use HTTPS (TLS 1.2+). Never use MD5 or SHA-1 for sensitive data. Encrypt sensitive data at rest. Disable weak TLS ciphers.

A03 — Injection

What it is: Untrusted user input is sent to an interpreter (SQL database, OS shell, LDAP) as part of a command. The interpreter cannot distinguish between the intended command and the attacker's injected data.

How it works: SQL Injection: A login form with username: admin'-- causes the query to become: SELECT * FROM users WHERE username='admin'--' AND password='' — the -- comments out the password check, granting access without a password.

Real breach: Heartland Payment Systems (2008): SQL injection was used to install malware on the payment processing network, exposing 130 million credit card numbers. It was one of the largest data breaches in history at that time.

DVWA — SQL Injection & Command Injection: DVWA's SQL Injection module (Low security) is completely unprotected. Entering: 1' OR '1'='1 in the User ID field returns all users from the database. Command Injection module allows OS commands to be appended using && or ; separators.

Prevention: Use parameterised queries / prepared statements — NEVER concatenate user input into SQL strings. Use ORM frameworks. Validate and sanitise all inputs. Apply least-privilege database accounts. Use WAF as an additional layer.

4. DVWA Vulnerability Mapping

DVWA (Damn Vulnerable Web Application) intentionally includes modules that map directly to OWASP Top 10 categories. Below is the complete mapping:

DVWA Module	OWASP Category	Attack Type
SQL Injection / SQL Injection (Blind)	A03 — Injection	Database data extraction
Command Injection	A03 — Injection	OS command execution
XSS (Reflected / Stored / DOM)	A03 — Injection	Script injection in browser
Brute Force	A07 — Auth Failures	Password guessing attack
Weak Session IDs	A07 — Auth & A02 — Crypto	Session hijacking
CSRF	A01 — Broken Access Control	Forged cross-site requests
File Inclusion	A01 — Broken Access Control	Unauthorized file access
File Upload	A04 — Insecure Design	Malicious file upload
Authorisation Bypass	A01 — Broken Access Control	Privilege escalation
Open HTTP Redirect	A10 — SSRF	Redirect to malicious site
Insecure CAPTCHA	A05 — Misconfiguration	CAPTCHA bypass
Cryptography	A02 — Crypto Failures	Weak encryption analysis
CSP Bypass	A05 — Misconfiguration	Content Security Policy bypass
JavaScript Attacks	A03 — Injection	Client-side logic tampering

5. Key Takeaways

- OWASP Top 10 provides a standardised framework for understanding the most critical web risks
- Broken Access Control is the #1 risk — always enforce server-side permission checks
- SQL Injection remains one of the most destructive attacks — parameterised queries are the fix
- Cryptographic failures are often silent — using MD5 or no encryption at all can go unnoticed until a breach

- DVWA maps directly to most OWASP categories — an invaluable tool for hands-on practice in a legal environment
- Security must be built into the design phase (A04) — retrofitting security is expensive and incomplete
- Logging and monitoring (A09) is often neglected — without it, breaches go undetected for years